

# GUIA DE PRIMEIROS PASSOS NIS2

As 4 Semanas para Iniciar a Conformidade NIS2 — Plano Prático para PMEs

Como usar este guia: Cada semana tem tarefas concretas com responsável, ferramentas e evidência esperada. Execute sequencialmente — cada semana constrói sobre a anterior. Ao final das 4 semanas, a PME terá a base de conformidade NIS2.

Empresa:

CISO Nomeado:

Início:

## SEMANA 1 — DIAGNÓSTICO E REGISTO

Objetivo da semana: Objetivo: saber onde estamos e tornar a conformidade NIS2 oficial

| Dia     | Tarefa / O Que Fazer                                                                                                                          | Responsável | Evidência Esperada                                  | ✓                        |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------|-------------|-----------------------------------------------------|--------------------------|
| SEG/TER | <b>Autoavaliação EE/EI</b><br>Usar a ferramenta Excel de autoavaliação. Determinar classificação. Documentar resultado.                       | CISO + CEO  | Documento de classificação assinado pelo CEO        | <input type="checkbox"/> |
| QUA     | <b>Registo no CNCS</b><br>Aceder a cncs.gov.pt → 'Entidades NIS2' → Iniciar processo de registo. Guardar referência.                          | CISO        | Email confirmação CNCS + número de referência       | <input type="checkbox"/> |
| QUI     | <b>Nomeação formal do CISO</b><br>Emitir carta formal de nomeação do CISO. Definir reporte direto à gestão. Comunicar.                        | CEO → CISO  | Carta de nomeação assinada pelo CEO                 | <input type="checkbox"/> |
| SEX     | <b>Inventário inicial de ativos críticos</b><br>Preencher as primeiras 5 linhas do Template de Inventário — focar nos sistemas mais críticos. | CISO + TI   | Inventário parcial iniciado — completar na semana 2 | <input type="checkbox"/> |

## SEMANA 2 — MFA E BACKUP IMUTÁVEL

Objetivo da semana: Objetivo: implementar as 2 medidas com maior ROI (bloqueiam 99,9% dos ataques de conta e ransomware)

| Dia     | Tarefa / O Que Fazer                                                                                                                                | Responsável | Evidência Esperada                                                 | ✓                        |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------|-------------|--------------------------------------------------------------------|--------------------------|
| SEG/TER | <b>Ativar MFA em e-mail (M365/Google Workspace)</b><br>M365: Azure Active Directory → Políticas de Acesso Condicional → Exigir MFA para todos.      | TI          | Screenshot do painel M365 com MFA 'Ativado' para 100% utilizadores | <input type="checkbox"/> |
| QUA     | <b>Ativar MFA em VPN e acesso remoto</b><br>Configurar MFA no servidor VPN. Revogar todos os acessos remotos sem MFA. Testar com 2 utilizadores.    | TI          | Lista de acessos VPN com confirmação MFA ativo em todos            | <input type="checkbox"/> |
| QUI     | <b>Configurar backup 3-2-1 com imutabilidade</b><br>Verificar backup atual. Se Veeam: ativar Immutability. Se Azure Backup: ativar Immutable Vault. | TI          | Log de backup + configuração imutabilidade documentada             | <input type="checkbox"/> |
| SEX     | <b>Teste de restauro de backup</b><br>Restaurar 3 ficheiros de teste — medir tempo de restauro (RTO). Documentar resultado.                         | TI          | Relatório de teste de restauro com RTO medido e assinado           | <input type="checkbox"/> |

| SEMANA 3 — POLÍTICA DE SEGURANÇA E FORMAÇÃO |                                                                                                                                                                            |                                                                                                                     |                                                                                 |                          |
|---------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|--------------------------|
| Objetivo da semana:                         |                                                                                                                                                                            | Objetivo: ter a base documental e os colaboradores sensibilizados — as 2 evidências mais pedidas em auditorias CNCS |                                                                                 |                          |
| Dia                                         | Tarefa / O Que Fazer                                                                                                                                                       | Responsável                                                                                                         | Evidência Esperada                                                              | ✓                        |
| SEG                                         | <b>Redigir a Política de Segurança da Informação (PSI)</b><br><i>Usar o template Word Aula 2.1. Incluir: âmbito, 10 regras de ouro, responsabilidades. Máx. 4 páginas.</i> | CISO                                                                                                                | Rascunho da PSI pronto para aprovação da gestão                                 | <input type="checkbox"/> |
| TER                                         | <b>Aprovação e assinatura da PSI pela gestão de topo</b><br><i>Reunião de 30 minutos para rever e aprovar a PSI. CEO assina formalmente. Obrigatório Art. 20.º NIS2.</i>   | CEO + Gestão                                                                                                        | PSI assinada pelo CEO com data de aprovação                                     | <input type="checkbox"/> |
| QUA/QUI                                     | <b>Sessão de formação em cibersegurança para todos</b><br><i>Sessão de 90 minutos: phishing, passwords, trabalho remoto, como reportar incidentes.</i>                     | CISO                                                                                                                | Lista presenças assinada + checklists de higiene assinadas por cada colaborador | <input type="checkbox"/> |
| SEX                                         | <b>Distribuição da PSI e confirmação de leitura</b><br><i>Enviar PSI a todos por e-mail com pedido de confirmação de leitura. Guardar confirmações.</i>                    | CISO                                                                                                                | Confirmações de leitura recebidas de ≥ 90% dos colaboradores                    | <input type="checkbox"/> |

| SEMANA 4 — PATCHES, IRP E VERIFICAÇÃO FINAL |                                                                                                                                                                                        |                                                                                                  |                                                                           |                          |
|---------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|--------------------------|
| Objetivo da semana:                         |                                                                                                                                                                                        | Objetivo: fechar vulnerabilidades críticas, ter IRP operacional e verificar conformidade inicial |                                                                           |                          |
| Dia                                         | Tarefa / O Que Fazer                                                                                                                                                                   | Responsável                                                                                      | Evidência Esperada                                                        | ✓                        |
| SEG                                         | <b>Scan de vulnerabilidades e atualização de patches crítico</b><br><i>Microsoft Defender Vulnerability Management ou Nessus Essentials. Aplicar patches CVSS ≥ 9.0 imediatamente.</i> |                                                                                                  | Relatório do scan + lista de patches aplicados com datas                  | <input type="checkbox"/> |
| TER/QUA                                     | <b>Redigir o Plano de Resposta a Incidentes (IRP)</b><br><i>Usar o template IRP Word Aula 2.2. Preencher: equipa, contactos CNCS/PJ/seguradora, procedimentos.</i>                     | CISO                                                                                             | IRP completo com todos os campos preenchidos e aprovado                   | <input type="checkbox"/> |
| QUI                                         | <b>Criar cartão de emergência NIS2 (plastificável)</b><br><i>Imprimir o Cartão de Emergência A5. Plastificar. Afixar na sala de TI e secretária do CISO.</i>                           | CISO                                                                                             | Cartão afixado em local visível — foto como evidência                     | <input type="checkbox"/> |
| SEX                                         | <b>Auto-auditoria de conformidade — semana 4</b><br><i>Usar a Checklist de Auto-Auditoria CNCS (PDF Aula 2.3). Verificar o que existe/falta. Criar plano.</i>                          | CISO                                                                                             | Relatório de auto-auditoria com estado de cada documento e plano de acção | <input type="checkbox"/> |

■ AO FINAL DAS 4 SEMANAS — O QUE A PME TERÁ FEITO:

- ☐ Registo CNCS: Referência de registo obtida
- ☐ CISO nomeado: Carta formal assinada pelo CEO
- ☐ MFA ativo: 100% das contas críticas com MFA
- ☐ Backup testado: RTO medido e documentado
- ☐ PSI aprovada: Assinada pela gestão, distribuída e confirmada
- ☐ Colaboradores formados: Listas de presença + checklists assinadas
- ☐ Patches críticos: CVSS ≥ 9.0 aplicados, scan documentado
- ☐ IRP operacional: Plano testado, contactos de emergência atualizados

APÓS AS 4 SEMANAS — PRÓXIMOS 90 DIAS:

Análise de risco documentada · Contratos de fornecedores com cláusulas NIS2 · Segmentação de rede · Scan externo · Tabletop exercise

ACOMPANHAMENTO DO PROGRESSO — DATAS E NOTAS

Semana 1 — Diagnóstico e Registo

Concluída em:

Notas / Gaps:

Semana 2 — MFA e Backup Imutável

Concluída em:

Notas / Gaps:

Semana 3 — PSI e Formação

Concluída em:

Notas / Gaps:

Semana 4 — Patches, IRP e Verificação

Concluída em:

Notas / Gaps:

VALIDAÇÃO DO PROGRAMA — ASSINATURAS

CISO:

Data conclusão:

CEO: